
SOC HOME LAB

Security Detection Report

Incident Analysis & Response Documentation

Analyst Home Lab

Date April 2026

Incidents 11 documented

Environment Kali → Windows 10 Pro / Windows Server 2016 → Splunk on CentOS

Framework MITRE ATT&CK;

Tools Splunk, Sysmon, Impacket, Hydra, Netcat, Mimikatz, Nmap, Wazuh

EXECUTIVE SUMMARY

Overview

This report documents 11 simulated attack scenarios executed in an isolated home lab environment. Each incident covers the attack technique, detection method, SPL query, key IOCs, MITRE ATT&CK mapping, Incident Response procedure from a Tier 1 SOC analyst perspective, and Root Cause Analysis with remediation. The attack chain progresses from initial reconnaissance through credential access, execution, persistence, lateral movement, Active Directory attacks, and persistent domain compromise via Golden Ticket — mirroring a realistic threat actor kill chain.

NETWORK TOPOLOGY

Machine	Role	NAT IP	Host-Only IP
Kali Linux	Attacker	192.168.15.129	192.168.67.24
Windows 10 Pro	Victim (domain-joined)	—	192.168.67.23
Windows Server 2016	Domain Controller	—	192.168.67.22
CentOS	Splunk SIEM	192.168.15.131	192.168.67.11

INCIDENTS OVERVIEW

#	Incident	Severity	Key Event ID	MITRE Tactic
01	Port Scan / Recon	MEDIUM	Sysmon EID 3	TA0043 Reconnaissance
02	Brute Force — Linux SSH	HIGH	linux_secure	TA0006 Credential Access
03	Brute Force — Windows SSH	HIGH	EID 4625	TA0006 Credential Access
04	Reverse Shell	CRITICAL	Sysmon EID 1, 3	TA0002 Execution
05	Persistence — Scheduled Task	HIGH	EID 4698	TA0003 Persistence
06	Credential Dumping — LSASS	CRITICAL	Sysmon EID 1	TA0006 Credential Access
07	Lateral Movement — PsExec	CRITICAL	EID 7045, 4624	TA0008 Lateral Movement
08	Kerberoasting	HIGH	EID 4769	TA0006 Credential Access
09	Pass-the-Hash	HIGH	EID 4624	TA0008 Lateral Movement
10	DCSync	HIGH	EID 4662	TA0006 Credential Access
11	Golden Ticket	CRITICAL	EID 4672	TA0006 Credential Access

01

INC-001

Port Scan / Recon

MEDIUM

Tool	Nmap (-sS -A)
Source	192.168.15.129 (Kali)
Target	192.168.15.130 (Windows)

DETECTION

Sysmon Event ID 3 detected a single source IP hitting more than 5 unique destination ports within a one-minute window. Threshold set above the observed legitimate traffic baseline to minimise false positives.

SPL QUERY

```
index=main EventCode=3
| bucket _time span=1m
| stats dc(DestinationPort) as unique_ports by _time, SourceIp, DestinationIp
| where unique_ports > 5
| sort -unique_ports
```

INDICATORS OF COMPROMISE

- Single IP hitting 20+ ports within seconds
- Parallel connection attempts — Nmap signature behaviour
- Ports 22, 135, 139, 445 probed simultaneously
- No scheduled scan or change ticket for the source IP
- Activity occurred outside business hours

MITRE ATT&CK;

TA0043 Reconnaissance | T1046 Network Service Discovery

Note: Threshold of 5 suits this lab. In production, baseline legitimate scanner traffic and set the threshold just above the observed maximum to reduce false positives.

INCIDENT RESPONSE — TIER 1 SOC ANALYST

1	Alert Review	Confirm EID 3 shows dc(DestinationPort) > 5 within a 1-minute bucket. Note source IP, destination IP, and timestamp.
2	Source IP Check	Is the source IP internal or external? Cross-reference IT scanner list and change ticket system.

3	TP/FP Decision	TP: External/unrecognised IP, no ticket, off-hours, 20+ ports in seconds. FP: Known IT scanner with a valid change ticket.
4	Pivot Search	Search same source IP across all event IDs. Look for follow-on EID 4625 or Sysmon EID 1.
5	Document	Record: source IP, destination, port list, timestamp, TP/FP decision. Attach Splunk export.
6	Escalate to T2	If TP: escalate with source IP, targeted ports, timestamp, and any follow-on activity.

ROOT CAUSE ANALYSIS

Root Cause	Ports 22, 135, 139, and 445 reachable from attacker subnet with no network-level controls.
Vulnerability	No firewall rules or VLAN segmentation preventing external hosts from reaching internal services.
Contributing Factor	Alert threshold not tuned to the environment.
Remediation	1. Firewall: block unsolicited inbound from untrusted subnets. 2. VLAN segmentation. 3. Disable SSH on Windows if not required. 4. Restrict NetBIOS ports. 5. Tune Splunk threshold.
Lessons Learned	Detecting recon early is the highest-value intervention — every subsequent attack depended on information gathered at this stage.

02

INC-002

Brute Force — Linux SSH

HIGH

Tool	Hydra
Source	192.168.15.129 (Kali)
Target	192.168.15.131 (CentOS / Splunk)

DETECTION

Linux auth logs (linux_secure sourcetype) — failed password entries extracted via regex, counted per source IP and target username. Any IP exceeding 5 failures is flagged.

SPL QUERY

```
index=main sourcetype=linux_secure "Failed password"
| rex "from (?P<src_ip>\d+\.\d+\.\d+\.\d+)"
| rex "for (?P<target_user>\w+) from"
| stats count by src_ip, target_user
| where count > 5
| sort -count
```

INDICATORS OF COMPROMISE

- High volume of failed SSH auth from single IP in short window
- Non-existent usernames — attacker cycling wordlist
- Rapid sequential attempts consistent with Hydra
- Multiple target usernames attempted from same source IP

MITRE ATT&CK;

TA0006 Credential Access | T1110 Brute Force | T1110.001 Password Guessing

Note: CRITICAL check: search for Accepted password from the same source IP. A successful login immediately escalates severity.

INCIDENT RESPONSE — TIER 1 SOC ANALYST

1	Alert Review	Confirm failed password spike in linux_secure. Note: source IP, target usernames, failure count, timeframe.
2	Source IP Check	Internal or external? Known admin machine? Any matching change ticket?
3	Check for Success	CRITICAL: Search for "Accepted password" from the same source IP. If found, severity escalates immediately.

4	TP/FP Decision	TP: External IP, non-existent usernames, rapid failures, no ticket. FP: Internal admin IP during maintenance.
5	Document	Record: source IP, targeted usernames, failure count, timestamps, whether a successful login followed.
6	Escalate to T2	Escalate with all findings. If a successful login was found, flag this explicitly.

ROOT CAUSE ANALYSIS

Root Cause	SSH exposed with password-based auth enabled and no brute force protection.
Vulnerability	No account lockout or rate limiting. No fail2ban. Password authentication accepted over SSH.
Contributing Factor	No firewall rules restricting which source IPs can reach SSH.
Remediation	1. Disable password-based SSH (PasswordAuthentication no). 2. Deploy fail2ban. 3. Restrict SSH to known admin IPs. 4. Disable root SSH login.
Lessons Learned	Password-based SSH is a critical misconfiguration. Key-based auth eliminates this attack vector entirely.

03

INC-003

Brute Force — Windows SSH

HIGH

Tool	Hydra
Source	192.168.15.129 (Kali)
Target	192.168.15.130 (Windows)

DETECTION

Windows Event ID 4625 (Failed Logon) — multiple failures against the same account. Detection pivots to Account_Name count because Source_Network_Address is blank when SSH is the attack vector — a known Windows logging limitation.

SPL QUERY

```
index=main EventCode=4625 Caller_Process_Name="*sshd*"
| stats count by Account_Name, Logon_Type, Caller_Process_Name
| where count > 5
| sort -count
```

INDICATORS OF COMPROMISE

- 5+ failed logons against same account in short window
- Logon Types 3, 8, or 9 — non-interactive, network-based
- Failures followed by successful logon (EID 4624) from same account
- Source_Network_Address blank — SSH vector does not populate this field on Windows

MITRE ATT&CK;

TA0006 Credential Access | T1110 Brute Force | T1110.001 Password Guessing

Note: To recover the attacker IP, correlate 4625 timestamps with Sysmon EID 3 at the same timeframe.

INCIDENT RESPONSE — TIER 1 SOC ANALYST

1	Alert Review	Confirm EID 4625 spike. Blank Source_Network_Address is expected for SSH attacks.
2	Recover Source IP	Cross-reference 4625 timestamps against Sysmon EID 3 to identify the attacker IP.
3	Check for Success	CRITICAL: Search EID 4624 for the same Account_Name immediately after the failure spike.

4	TP/FP Decision	TP: Rapid failures, Logon Types 3/8/9, off-hours, no ticket. FP: User locked out after a password change.
5	Document	Record: targeted account, logon types, failure count, timestamps, recovered source IP.
6	Escalate to T2	Escalate with account name, failure count, logon types, recovered source IP.

ROOT CAUSE ANALYSIS

Root Cause	Windows OpenSSH exposed with password auth enabled and no account lockout policy configured.
Vulnerability	No account lockout policy — unlimited password attempts permitted.
Logging Gap	Windows does not populate Source_Network_Address in EID 4625 for SSH. Compensate with Sysmon EID 3.
Remediation	1. Configure account lockout: 5 failures triggers 30-minute lockout. 2. Disable password-based SSH. 3. Restrict inbound SSH to known admin IPs.
Lessons Learned	Pivoting to Sysmon EID 3 to recover the blank source IP demonstrates detection engineering depth.

04

INC-004

Reverse Shell

CRITICAL

Tool	Netcat + PowerShell TCP socket
Source	192.168.15.129 (Kali) — listener port 4444
Target	192.168.15.130 (Windows)

DETECTION

Sysmon EID 1 detected PowerShell launched with -ExecutionPolicy Bypass from cmd.exe. Sysmon EID 3 detected powershell.exe establishing outbound TCP to non-standard port 4444.

SPL QUERY

```
# Outbound to non-standard port
index=main EventCode=3 Image="*powershell*"
| where DestinationPort != 80 AND DestinationPort != 443
| table _time, User, Image, DestinationIp, DestinationPort

# ExecutionPolicy Bypass in command line
index=main EventCode=1 Image="*powershell*" CommandLine="*ExecutionPolicy*Bypass*"
| table _time, User, Image, CommandLine, ParentImage
```

INDICATORS OF COMPROMISE

- powershell.exe initiating outbound TCP to external IP
- Non-standard destination port (4444) — not HTTP/HTTPS
- -ExecutionPolicy Bypass present in command line
- cmd.exe as parent process of powershell.exe

MITRE ATT&CK;

TA0002 Execution | TA0011 C2 | T1059.001 PowerShell | T1571 Non-Standard Port

Note: Port-based detection misses reverse shells on port 443. Improvement: flag powershell.exe making any outbound connection combined with destination IP reputation.

INCIDENT RESPONSE — TIER 1 SOC ANALYST

1 Alert Review	Confirm EID 1 (PowerShell with Bypass) and EID 3 (outbound non-standard port). Verify correlation by User and timestamp.
----------------	--

2	Assess Legitimacy	Legitimate scripts are signed and do not require Bypass at runtime. No legitimate business tool needs port 4444.
3	TP/FP Decision	TP: powershell.exe outbound on non-standard port with -ExecutionPolicy Bypass, no ticket. Almost always a true positive.
4	Record C2 Details	Note the destination IP and port from EID 3 — this is the attacker's C2 address.
5	Document	Record: compromised user, C2 IP and port, timestamp, command line from EID 1. Open a P1 ticket.
6	Escalate to T2	Escalate immediately as CRITICAL. Include: C2 IP, destination port, compromised user, command line.

ROOT CAUSE ANALYSIS

Root Cause	PowerShell execution policy bypassable with a runtime flag. No application whitelisting in place.
Vulnerability	No AppLocker or WDAC policy. Outbound firewall allowed TCP to arbitrary external IPs on port 4444.
Contributing Factor	No egress filtering — outbound connections to non-business IPs and ports permitted without inspection.
Remediation	1. Enable PowerShell Constrained Language Mode. 2. Set execution policy to AllSigned. 3. Egress firewall blocking direct TCP to arbitrary ports. 4. Deploy PowerShell Script Block Logging (EID 4104). 5. Enable AMSI.
Lessons Learned	A reverse shell gives the attacker an interactive session. Every subsequent incident (5-7) was possible because this shell was not detected and contained in time.

05

INC-005

Persistence — Scheduled Task

HIGH

Tool	schtasks.exe via reverse shell
Source	192.168.15.129 (Kali) — via reverse shell
Target	192.168.15.130 (Windows)

DETECTION

Windows Event ID 4698 — scheduled task created with suspicious keywords in the TaskContent field: ExecutionPolicy, Bypass, shell, temp.

SPL QUERY

```
index=main EventCode=4698
| search TaskContent="*ExecutionPolicy*" OR TaskContent="*ByPass*"
  OR TaskContent="*shell*" OR TaskContent="*temp*"
| table _time, Account_Name, Task_Name, TaskContent
| sort _time
```

INDICATORS OF COMPROMISE

- Task named after a legitimate Windows process (masquerading)
- LogonTrigger — task survives reboots and reconnects automatically
- ExecutionPolicy Bypass embedded in task payload
- Task created and running as SYSTEM account
- Created outside business hours with no change ticket

MITRE ATT&CK;

TA0003 Persistence | T1053.005 Scheduled Task

Note: Persistence is established within minutes of initial access. Detecting Incident 4 quickly prevents Incident 5 from occurring.

INCIDENT RESPONSE — TIER 1 SOC ANALYST

1	Alert Review	Confirm EID 4698. Review: Task_Name (masquerading?), Account_Name (SYSTEM suspicious), TaskContent keywords.
2	Assess Legitimacy	Legitimate tasks are signed and do not use Bypass in their payload.
3	TP/FP Decision	TP: SYSTEM-created task, Bypass/shell keywords, off-hours, no ticket. FP: Software installer with a change ticket.

4	Check Active Execution	Is the task already running? Check EID 3 for outbound powershell.exe connections at the same timestamp.
5	Document	Record: task name, creation time, Account_Name, TaskContent, trigger type, and any correlated C2 activity.
6	Escalate to T2	Escalate with task details and C2 activity. T2 determines whether an active session exists.

ROOT CAUSE ANALYSIS

Root Cause	Attacker had SYSTEM-level access (via reverse shell in INC-004) with no policy restricting malicious task creation.
Vulnerability	No AppLocker/WDAC policy blocking script execution from user-writable paths. No real-time EID 4698 alerting.
Contributing Factor	Persistence was only possible because the reverse shell (INC-004) was not contained.
Remediation	1. AppLocker/WDAC: block script execution from Temp, Desktop. 2. Group Policy: restrict schtasks.exe. 3. Real-time EID 4698 alert. 4. Audit all existing scheduled tasks.
Lessons Learned	Persistence is established within minutes of initial access. Detect INC-004 quickly and INC-005 never occurs.

06

INC-006

Credential Dumping — LSASS

CRITICAL

Tool	comsvcs.dll MiniDump + Mimikatz
Source	192.168.15.130 (Windows) — local attack
Target	192.168.15.130 (Windows) — LSASS process

DETECTION

Sysmon EID 1 detected Mimikatz executed with sekurlsa arguments. Also detected rundll32.exe invoking comsvcs.dll MiniDump targeting the LSASS PID.

SPL QUERY

```
# Mimikatz binary execution
index=main EventCode=1 Image="*mimikatz*"
| table _time, User, Image, CommandLine | sort _time

# comsvcs.dll MiniDump targeting LSASS
index=main EventCode=1 Image="*rundll32*" CommandLine="*comsvcs*"
| table _time, User, Image, CommandLine | sort _time
```

INDICATORS OF COMPROMISE

- mimikatz.exe executed with sekurlsa arguments
- rundll32.exe invoking comsvcs.dll MiniDump targeting LSASS PID
- Dump file written to C:\Users\Public\lsass.dmp
- LSASS access attempt is critical regardless of extraction success

MITRE ATT&CK;

TA0006 Credential Access | T1003.001 LSASS Memory

Note: Extraction failed due to Windows 11 24H2 LSASS PPL. Detection is based on the attempt — the attempt alone confirms SYSTEM-level access.

INCIDENT RESPONSE — TIER 1 SOC ANALYST

1	Alert Review	EID 1 with mimikatz in Image, or rundll32 with comsvcs in CommandLine. Automatic CRITICAL — no TP/FP debate.
2	Check Dump File	Note whether a dump file path appears in CommandLine. If it exists, treat credentials as potentially extracted.

3	Pivot to Lateral Move	Search EID 4624 Logon Type 3 across all machines filtering for the compromised account.
4	Document	Record: compromised user, command line, dump file path if present, whether PPL was active. Open P1 ticket.
5	Escalate to T2	Escalate as CRITICAL immediately. Include: whether dump file exists, active accounts, any lateral movement.

ROOT CAUSE ANALYSIS

Root Cause	Attacker had SYSTEM-level access — consequence of INC-004 and INC-005 not being contained.
Vulnerability	LSASS PPL not enabled. No Credential Guard deployed. Mimikatz placed on disk without AV detection.
Contributing Factor	No EDR monitoring LSASS handle access. Credential Guard was not deployed.
Remediation	1. Enable Credential Guard. 2. Enable LSASS PPL: RunAsPPL = 1. 3. EDR: alert on any process opening a handle to LSASS. 4. Block known credential dumping tools.
Lessons Learned	Once NTLM hashes are obtained the attacker moves laterally via Pass-the-Hash without knowing plaintext passwords.

07

INC-007

CRITICAL

Lateral Movement — PsExec

Tool	Impacket PsExec
Source	192.168.15.129 (Kali)
Target	192.168.15.130 (Windows)

DETECTION

Impacket PsExec drops a randomly named binary to C:\Windows\ over SMB, creates a service as SYSTEM, then deletes it immediately. Three correlated events confirm the attack.

SPL QUERY

```
# Random binary spawned by services.exe
index=main EventCode=1 ParentImage="*services.exe*" Image="C:\\Windows\\*.exe"
| where NOT match(Image, "(?i)(svchost|sppsvc|TrustedInstaller|msiexec)")

# New service created/deleted rapidly
index=main EventCode=7045 | table _time, ServiceName, ServiceFileName | sort _time

# Logon Type 3 – correlate timestamps
index=main EventCode=4624 Logon_Type=3 | table _time, Account_Name, Logon_Type, IpAddress
```

INDICATORS OF COMPROMISE

- Randomly named executable in C:\Windows\ — legitimate PsExec uses PSEXESVC.exe
- Binary spawned directly by services.exe as NT AUTHORITY\SYSTEM
- Service created and deleted within seconds — Impacket cleanup behaviour
- Logon Type 3 from external IP at same timestamp as service creation

MITRE ATT&CK;

TA0008 Lateral Movement | T1021.002 SMB/Admin Shares | T1543.003 Windows Service

Note: Key differentiator: PSEXESVC.exe = legitimate use. A random string (e.g. xvtqrs.exe) confirms Impacket.

INCIDENT RESPONSE — TIER 1 SOC ANALYST

1	Alert Review	Correlate EID 7045, Sysmon EID 1, EID 4624 Logon Type 3 by timestamp. All three in the same minute window confirms Impacket PsExec.
---	--------------	---

2	Binary Name Check	PSEXESVC.exe = legitimate use. A random string confirms Impacket. This is the key differentiator.
3	Identify Account	Which account was used for Logon Type 3? Cross-reference with previously compromised accounts.
4	TP/FP Decision	TP: Random binary name, external source IP, no ticket. FP: IT team with PSEXESVC.exe, valid change ticket.
5	Scope Assessment	Search for the same Logon Type 3 pattern on ALL other machines. Map every machine the attacker reached.
6	Escalate to T2	Escalate as CRITICAL: attacker IP, account, binary name, all machines showing Logon Type 3.

ROOT CAUSE ANALYSIS

Root Cause	Attacker obtained NTLM hashes via LSASS dump (INC-006) and used Pass-the-Hash over SMB.
Vulnerability	Admin\$ SMB share reachable from non-domain machines. No SMB signing enforced.
Contributing Factor	Credential dump in INC-006 was not contained. Once hashes are exfiltrated, lateral movement follows within minutes.
Remediation	1. Disable Admin\$ on workstations. 2. Enforce SMB signing. 3. Tiered admin model. 4. Deploy Credential Guard. 5. Network segmentation.
Lessons Learned	The PsExec service creates and deletes itself in seconds. Without real-time correlation of all three event IDs, this passes completely unnoticed.

08

INC-008

Kerberoasting

HIGH

Tool	Impacket GetUserSPNs
Source	192.168.67.24 (Kali)
Target	192.168.67.22 (DC — myhomelab.local)

DETECTION

Any domain user can request a Kerberos service ticket for any SPN-registered account. The attacker forces RC4 encryption (0x17) instead of AES (0x12) to obtain a hash crackable offline. EID 4769 with Ticket_Encryption_Type=0x17 is the detection trigger.

SPL QUERY

```
index=main EventCode=4769 Ticket_Encryption_Type=0x17
| table _time, Account_Name, Service_Name, Ticket_Encryption_Type, Client_Address
| sort -_time
```

INDICATORS OF COMPROMISE

- EID 4769 with Ticket_Encryption_Type=0x17 (RC4) — modern AD uses AES (0x12)
- Requesting account: Lisa@MYHOMELAB.LOCAL (low-privilege domain user)
- Targeted service: sqlsvc (LastLogon: never — unmonitored account)
- Client_Address: 192.168.67.24 (Kali — non-domain machine)
- Failure_Code: 0x0 — ticket issued, hash retrievable offline

MITRE ATT&CK;

TA0006 Credential Access | T1558.003 Kerberoasting

Note: Hash cracking via rockyou.txt was unsuccessful (admin@123 not in wordlist). Alert on ANY EID 4769 with 0x17 regardless of cracking outcome.

INCIDENT RESPONSE — TIER 1 SOC ANALYST

1	Alert Review	Confirm EID 4769 with Ticket_Encryption_Type=0x17. Note: requesting account, targeted service, Client_Address, Failure_Code.
2	RC4 Significance	Modern AD uses AES (0x12). RC4 (0x17) is only requested when an attacker forces a downgrade to get a crackable hash.
3	Scope Check	How many SPNs were requested? One = targeted. Multiple in rapid succession = full sweep of all service accounts.

4	Check Lisa's Account	Flag Lisa's account alongside the service account. Check for other unusual activity.
5	TP/FP Decision	Almost always TP. Exception: legacy systems (pre-Server 2008) that legitimately use RC4.
6	Escalate to T2	T2 will reset sqlsvc password immediately, audit all SPNs, and investigate Lisa's account.

ROOT CAUSE ANALYSIS

Root Cause	Service account sqlsvc registered with an SPN and configured with a weak password. RC4 encryption not disabled.
Vulnerability	sqlsvc password was weak and offline-crackable. RC4 not disabled. LastLogon: never — unmonitored target.
Contributing Factor	sqlsvc over-privileged relative to its function. No alerting on EID 4769 with RC4 before this rule.
Remediation	1. Use gMSA — auto-rotates passwords. 2. Minimum 25-character passwords. 3. Enforce AES-only: msDS-SupportedEncryptionTypes = 24. 4. Audit all SPNs. 5. Alert on all EID 4769 with 0x17.
Lessons Learned	Kerberoasting is silent from the DC — it looks like a normal ticket request. The only detection signal is the RC4 downgrade.

09

INC-009

Pass-the-Hash

HIGH

Tool	Impacket PsExec with NTLM hash
Source	192.168.67.24 (Kali)
Target	192.168.67.23 (Windows 10 Pro)

DETECTION

EID 4624 Logon Type 3 from an external IP where Logon_Process shows NtLmSsp instead of Kerberos. In a domain, admin logins between machines use Kerberos by default. NTLM from a non-domain IP is the smoking gun.

SPL QUERY

```
index=main EventCode=4624 Logon_Type=3
| search Logon_Process="NtLmSsp" Account_Name="Administrator"
| table _time, Account_Name, Logon_Type, src_ip, Workstation_Name, Logon_Process
| sort -_time
```

INDICATORS OF COMPROMISE

- EID 4624 Logon Type 3 with Logon_Process=NtLmSsp — NTLM used instead of Kerberos
- Account_Name: Administrator
- src_ip: 192.168.67.24 (Kali — non-domain machine)
- Workstation_Name: blank — attacker machine not domain-joined
- No preceding interactive logon (EID 4648) for the same account

MITRE ATT&CK;

TA0008 Lateral Movement | T1550.002 Pass-the-Hash

Note: Pass-the-Hash requires zero cracking — the NTLM hash is the credential. The attacker obtained the Administrator hash in INC-006 and used it directly.

INCIDENT RESPONSE — TIER 1 SOC ANALYST

1	Alert Review	EID 4624 Logon Type 3 from external IP with Logon_Process = NtLmSsp. Domain admin logins use Kerberos by default. NTLM from a non-domain IP is immediately suspicious.
2	NtLmSsp Significance	Confirms NTLM authentication. The attacker never needed the plaintext password — the hash alone is sufficient.

3	Scope Check	Check all EID 4624 Logon Type 3 events from the same source IP across all hosts to determine lateral movement scope.
4	Correlate with INC-006	This attack was enabled by the LSASS dump in INC-006. Containment of INC-006 would have prevented this.
5	TP/FP Decision	TP. NtLmSsp Logon Type 3 from a non-domain IP as Administrator is not legitimate activity.
6	Escalate to T2	T2 will: rotate Administrator password, force Kerberos-only auth, investigate lateral movement scope.

ROOT CAUSE ANALYSIS

Root Cause	NTLM hash for Administrator obtained via LSASS dump (INC-006) and used directly without cracking.
Vulnerability	NTLM authentication permitted from non-domain machines. Admin\$ accessible from external IPs. No SMB signing.
Contributing Factor	INC-006 credential dump was not contained. A single Administrator hash grants access to all machines where that account exists.
Remediation	1. Deploy Credential Guard to protect NTLM hashes. 2. Enforce SMB signing. 3. Disable NTLM where Kerberos is available. 4. Tiered admin model. 5. Network segmentation.
Lessons Learned	Pass-the-Hash requires zero cracking — the hash is the credential. A single unrotated hash provides persistent lateral movement capability across every machine sharing that account.

10

INC-010

DCSync

HIGH

Tool	Impacket secretsdump (DRSUAPI method)
Source	192.168.67.24 (Kali)
Target	192.168.67.22 (Domain Controller)

DETECTION

DCSync abuses Active Directory's DRSUAPI replication protocol. The attacker impersonates a DC and requests all domain hashes including krbtgt. Correct detection: EID 4662 with DS-Replication GUIDs from a non-DC source IP.

DETECTION GAP: EID 4662 did not fire on Windows Server 2016 in this lab despite correct ADSI object auditing configuration. This is a documented real-world limitation.

SPL QUERY

```
index=main EventCode=4662
| search Properties="*1131f6aa*" OR Properties="*1131f6ab*"
| table _time, Account_Name, Object_Name, Properties
| sort -_time
```

INDICATORS OF COMPROMISE

- EID 4662 with DS-Replication-Get-Changes GUIDs (1131f6aa, 1131f6ab) from non-DC source
- Account_Name: domain admin account used (Administrator)
- Source IP is not a registered Domain Controller IP
- Large volume of NTLM hashes retrieved in short timeframe
- krbtgt hash retrieved — enables Golden Ticket attacks

MITRE ATT&CK;

TA0006 Credential Access | T1003.006 DCSync

Note: EID 4662 did not generate in this lab on Windows Server 2016 despite correct audit policy. Microsoft Defender for Identity detects DCSync at the network level independent of Windows event logging.

INCIDENT RESPONSE — TIER 1 SOC ANALYST

1	Attack Summary	Attacker used DRSUAPI to pull all domain hashes including krbtgt, Administrator, and all service accounts. All domain credentials must be treated as compromised.
---	----------------	---

2	Hashes Obtained	Administrator, krbtgt, sqlsvc, lisa, john, and all machine account hashes. krbtgt hash enables Golden Ticket attacks.
3	Severity Assessment	Critical severity. krbtgt compromise enables forged Kerberos tickets valid for any user, any resource, any duration.
4	Detect in Splunk	Search EID 4662 for DS-Replication GUIDs. If 4662 not generating, check Microsoft Defender for Identity.
5	Document	Record: account used, source IP, timestamp, hashes confirmed retrieved, detection gap if 4662 produced no events. Open P1 ticket.
6	Escalate to T2	Escalate as CRITICAL. T2: reset krbtgt password twice, rotate all service account passwords, initiate full domain compromise response.

ROOT CAUSE ANALYSIS

Root Cause	Domain Administrator credentials compromised via Pass-the-Hash (INC-009) and used to abuse AD replication protocol.
Vulnerability	Any account with DS-Replication-Get-Changes-All can perform DCSync. Built-in Administrator always has this right.
Contributing Factor	Chain of uncontained incidents: INC-006 (LSASS dump) -> INC-009 (Pass-the-Hash) -> INC-010 (DCSync) -> INC-011 (Golden Ticket).
Detection Gap	EID 4662 did not fire on Windows Server 2016 in this lab despite correct audit policy. Documented as a real-world logging limitation.
Remediation	1. Reset krbtgt password twice. 2. Rotate all service account and admin passwords. 3. Tiered admin model. 4. Validate EID 4662 in production via purple team. 5. Deploy Microsoft Defender for Identity.
Lessons Learned	DCSync uses a legitimate AD protocol with no code on the DC. The real prevention is stopping privilege escalation earlier in the chain.

11

INC-011

Golden Ticket

CRITICAL

Tool	Impacket ticketer + psexec
Source	192.168.67.24 (Kali)
Target	192.168.67.22 (Domain Controller)

DETECTION

The Golden Ticket attack uses the krbtgt NTLM hash to forge a TGT entirely offline — no interaction with the DC required. Because the KDC never issued the ticket, no EID 4768 (TGT Request) is generated. The only observable evidence is EID 4672 (Special Privileges Assigned) for an account that does not exist in Active Directory.

Lab confirmed: forged ticket created for "fakeadmin" (non-existent user). DC accepted the ticket and granted a SYSTEM shell. EID 4672 fired 4 times. EID 4768: 0 events.

SPL QUERY

```
# PRIMARY — EID 4672 for account with no AD existence
index=main EventCode=4672
| stats count by Account_Name
| search NOT [
  search index=main EventCode=4720
  | stats count by Account_Name
  | fields Account_Name
]

# DIRECT — known phantom account
index=main EventCode=4672 Account_Name="fakeadmin"
| table _time, Account_Name, Privileges
| sort -_time

# CONFIRM OFFLINE FORGERY — no 4768 should exist
index=main EventCode=4768 Account_Name="fakeadmin"
| table _time, Account_Name, Client_Address

# Expected: 0 events — proves ticket was never issued by KDC
```

INDICATORS OF COMPROMISE

- EID 4672 for an account that does not exist in Active Directory
- NO corresponding EID 4768 — ticket was forged offline, KDC never issued it

- Account_Name does not appear in Get-ADUser -Filter * output
- SYSTEM shell obtained on DC from non-domain machine
- Default Golden Ticket validity is 10 years — anomalous ticket lifetime

MITRE ATT&CK;

TA0006 Credential Access | T1558.001 Golden Ticket | TA0008 Lateral Movement

Note: Standard Kerberos logging (EID 4768/4769) only covers tickets issued by the KDC. Golden Ticket bypasses the KDC entirely. Microsoft Defender for Identity detects Golden Tickets via anomalous ticket lifetimes and forged PAC structure analysis.

INCIDENT RESPONSE — TIER 1 SOC ANALYST

1	Alert Review	EID 4672 for an account that does not exist in AD. Confirm by running Get-ADUser on the DC — "cannot find object" confirms phantom account.
2	Check for 4768	Search EID 4768 for the same account name. Zero results confirms the ticket was forged offline — this is the defining characteristic of a Golden Ticket.
3	Severity Assessment	Automatic CRITICAL. A forged TGT accepted by the DC means the attacker has full domain access as any user with no expiry.
4	Scope Assessment	Check EID 4672 across all DCs for the same account name. Check EID 4624 Logon Type 3 from the attacker IP across all machines.
5	Pre-requisite Trace	Golden Ticket requires the krbtgt hash. Trace back to DCSync (INC-010) — if DCSync was not contained, Golden Ticket was inevitable.
6	Document	Record: phantom account name, timestamp of 4672 events, absence of 4768, source IP, SYSTEM shell on DC confirmed. Open P1 ticket.
7	Escalate to T2	T2: reset krbtgt password TWICE with 10-hour gap, invalidate all Kerberos tickets domain-wide, rotate all privileged account passwords, deploy Defender for Identity.

ROOT CAUSE ANALYSIS

Root Cause	krbtgt NTLM hash obtained via DCSync (INC-010) enabled offline forgery of Kerberos tickets with no DC interaction required.
Attack Chain	INC-006 (LSASS dump) -> INC-009 (Pass-the-Hash) -> INC-010 (DCSync, obtained krbtgt) -> INC-011 (Golden Ticket, SYSTEM on DC as ghost user).
Why Detection Is Hard	No EID 4768 is generated because the KDC never issued the ticket. Only EID 4672 for an unknown account is observable.
Vulnerability	No mechanism prevents an attacker with the krbtgt hash from forging tickets offline. This is a fundamental Kerberos design characteristic.

Remediation

1. Reset krbtgt password TWICE with 10-hour gap (single reset insufficient). 2. Invalidate all Kerberos tickets domain-wide. 3. Rotate all admin and service account passwords. 4. Deploy Microsoft Defender for Identity. 5. Alert on EID 4672 for accounts not present in AD.

Lessons Learned

Golden Ticket is the endgame of AD compromise. Once an attacker has the krbtgt hash they have persistent, stealthy domain access that survives password resets of every account except krbtgt itself.

DETECTION & IR SUMMARY

Quick Reference

#	Incident	Sev	Key Event	T1 Action	RCA Fix
01	Port Scan	MEDIUM	Sysmon EID 3	Pivot follow-on, escalate TP	Firewall + Segmentation
02	BF Linux	HIGH	linux_secure	Check success, escalate	fail2ban + Key Auth
03	BF Windows	HIGH	EID 4625	Correlate EID 3 for src IP	Account Lockout GPO
04	Reverse Shell	CRITICAL	EID 1, 3	Record C2, escalate P1	AppLocker + Egress FW
05	Persistence Task	HIGH	EID 4698	Check active C2, escalate	AppLocker + Least Priv
06	LSASS Dump	CRITICAL	Sysmon EID 1	Pivot Logon Type 3, P1	Credential Guard + PPL
07	Psexec Lateral	CRITICAL	EID 7045, 4624	Binary name check, scope all	SMB Signing + Tiered Admin
08	Kerberoasting	HIGH	EID 4769	Check SPN scope, flag user	gMSA + AES-Only
09	Pass-the-Hash	HIGH	EID 4624	Check NtLmSsp, scope machines	Credential Guard + NTLM off
10	DCSync	HIGH	EID 4662	Escalate CRITICAL, krbtgt x2	Defender Identity + Tiered
11	Golden Ticket	CRITICAL	EID 4672	Verify no 4768, krbtgt x2	Defender Identity + Reset

Full attack chain: INC-006 (LSASS dump) → INC-009 (Pass-the-Hash) → INC-010 (DCSync) → INC-011 (Golden Ticket). Each uncontained incident directly enabled the next. Reset krbtgt password TWICE with a 10-hour gap to remediate Golden Ticket.